Implementing GDPR in your company

SieuwertExplains

youtube.com/@sieuwertexplains

Img: generated by ChatGPT

Agenda

A5.34 – Legal obligation, Protection of PII and Privacy

GDPR – Personal data

GDPR – Processing activities

GDPR - Register of processing activities

GDPR - Controller VS. Processor and DPA

GDPR – DPO, privacy by design, requests, …

Conclusion

ISO 27001 Standard Controls

37 **organizational** controls

5.1	5.20
5.2	5.21
5.3	5.22
5.4	5.23
5.5	5.24
5.6	5.25
5.7	5.26
5.8	5.27
5.9	5.28
5.10	5.29
5.11	5.30
5.12	5.31
5.13	5.32
5.14	5.33
5.15	5.34
5.16	5.35
5.17	5.36
5.18	5.37
5.19	

Focus of this video

8 **people** controls

6.1
6.2
6.3
6.4
6.5
6.6
6.7
6.8

14 **physical** controls

7.1
7.2
7.3
7.4
7.5
7.6
7.7
7.8
7.9
7.10
7.11
7.12
7.13
7.14

34 **technological** controls

8.1	8.20
8.2	8.21
8.3	8.22
8.4	8.23
8.5	8.24
8.6	8.25
8.7	8.26
8.8	8.27
8.9	8.28
8.10	8.29
8.11	8.30
8.12	8.31
8.13	8.32
8.14	8.33
8.15	8.34
8.16	
8.17	
8.18	
8.19	

5.31 Legal, statutory, regulatory and contractual requirements

"Legal, statutory, regulatory and contractual requirements relevant to information security and the organization's approach to meet these requirements shall be identified, documented and kept up to date."

There should be documentation that shows we took a serious look at relevant laws, legislation, and other requirements.

Template: Summary of laws and regulations

Suggestions for content:

- **GDPR for personal data**
- HR / labor law
- Finance / tax law

Document ID: E4	Document name: Information Security Policy
Version: 0.5	Owner: CEO
Date: 01-01-2023	Classification: Confidential

LOGO

Summary of laws and regulations

The following overview contains laws and regulations that apply to [ORGANIZATION] and that may have interfaces with information security. It also keeps track of which processes it applies to, and to what extent they are complied with.

Privacy

Law/Regulation/contract	Business processes	Requirements for our ISMS	Status of implementation
General Data Protection Regulation Uitvoeringswet Algemene Verordening Gegevensbescherming (UAVG)	Almost all processes, [SECTOR SPECIFIC PROCESSES] and HR contain special categories of- and sensitive data, many supporting processes also use personal data.		Implemented. [ACTIONS TAKEN]. We have published a privacy statement: [LINK PRIVACY STATEMENT]
Telecommunicatiewet (Tw)	External websites that use cookies or other methods to track visitors.		Implemented. For example, by adding a cookie statement [LINK COOKIE STATEMENT]

Healthcare [if applicable]

Law/Regulation/contract	Business processes	Requirements for our ISMS	Status of implementation
Wet op de geneeskundige behandelingsovereenkomst (WGBO) Wet op de beroepen in de individuele gezondheidszorg (Wet BIG) Wet kwaliteit, klachten en geschillen zorg (Wkkgz) Uitvoeringsbesluit Wkkgz Wet verplichte geestelijke gezondheidszorg (Wvggz) Wet zorg en dwang (Wzd) Wet forensische zorg (Wfz) Burgerlijk Wetboek (BW) boek 1 (m.n. bepalingen curatorschap en mentorschap) Gezondheidswet Zorgverzekeringswet (Zvw) Wet langdurige zorg (Wlz)	Healthcare processes	Retention period for medical information, medical confidentiality (limited sharing of information)	All of these laws are implemented and enforced. In general, this is not done by law, but with an integrated approach that has been developed to meet the requirements of Dutch law. Where necessary, advice is given by the company lawyer.

5.34 Privacy and protection of personal identifiable information (PII)

"The organization shall identify and meet the requirements regarding the preservation of privacy and protection of PII according to applicable laws and regulations and contractual requirements."

If you handle personal data, you must comply with the **General Data Protection Regulation (GDPR)**.

Most organizations need:

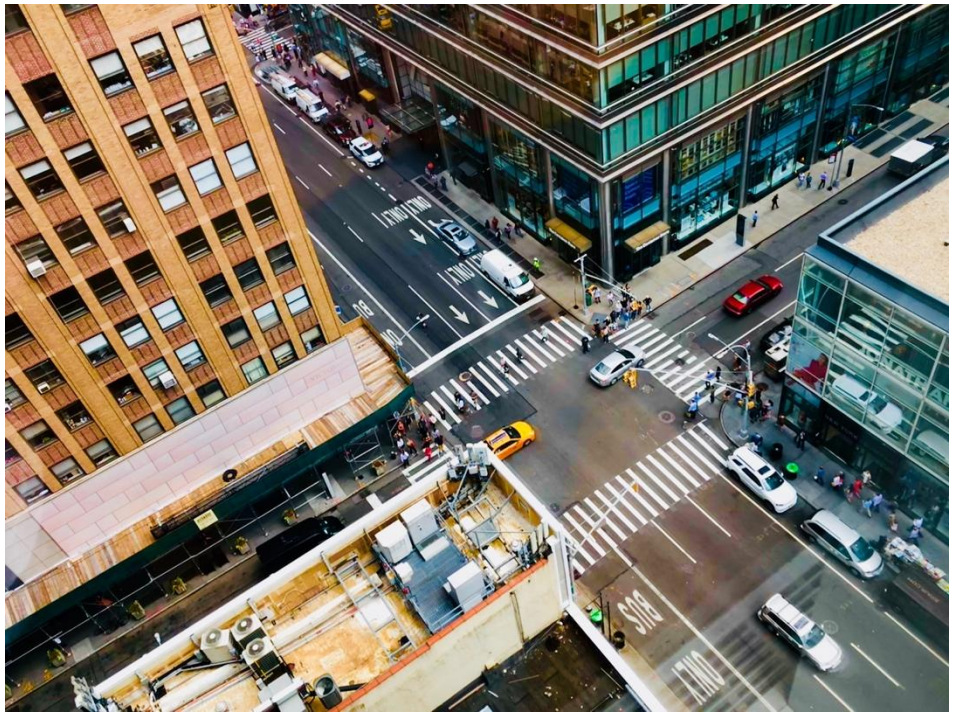
- Register of processing activities
- Processing agreements with certain suppliers
- A privacy statement on the website
- Procedure for Data Protection Impact Assessments (DPIA)
- Decide whether a Data Protection Officer (DPO) role is needed
- Procedure and register of data breaches

Note: other countries or states have similar laws, but I am certified information privacy professional for Europe (CIPP/E) so I will focus on GDPR

What is the goal of the GDPR?

Traffic

Road Traffic Law



Digital traffic

GDPR

Agenda

A5.34 – Legal obligation, Protection of PII and Privacy

GDPR – Personal data

GDPR – Processing activities

GDPR - Register of processing activities

GDPR - Controller VS. Processor and DPA

GDPR – DPO, privacy by design, requests, …

Conclusion

Definition personal data

Personal data are any information which:

1) are related to;
2) an identified, or;
3) identifiable;
4) natural person.

The natural person to whom the data relates, is called the data subject.

Bron: handleiding AVG

What is personal data?

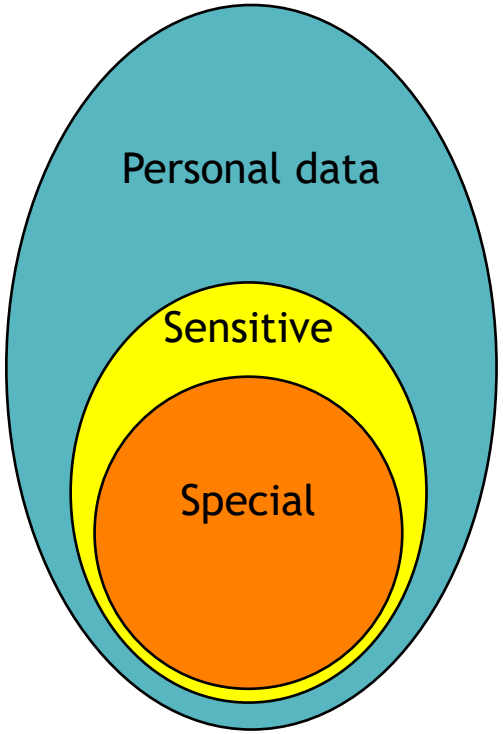
The price of a (new, stock) car in a catalog of a car dealer is not personal data, as this data does not pertain to a person.

When someone records that ‘John Doe’ has bought a (unique) car for a certain price, then there is personal data, as the data about the car pertain to the person John Doe.

Note: A person is identifiable in case their identity has not yet been established, but this can be reasonably done without disproportionate effort: e.g. via IP address

kevin-schmid--grs8iMGqQE-unsplash

Special and Sensitive personal data



Some data is defined as special: health data, biometrics, information on gender or religion.

However, also data that are not considered 'special' within the meaning of the regulation can, according to notional privacy authorities, be considered ***sensitive***.

For example, think of:

- Financial data.
- Location data.
- Personal data of criminal nature: these are so sensitive that there are special regulations for this. This is only allowed if it is supervised by the government, or if it is specifically regulated by law.
- SSN/National identification number: This kind of 'national' data, but may only be used for purposes prescribed by law.

Special and sensitive data comes with additional rules

Are you allowed to process personal data?

In principle, yes	*Yes, but*	*No, unless*

Personal data: yes, if

- Lawful, fair and transparent.
- Collected for specified, explicit and legitimate purposes, not incompatible.
- Adequate and relevant, limited to necessary (data minimization).
- Accurate and kept up to date.
- Kept no longer than necessary
- Appropriate technical and organizational measures
- Accountability

Are you allowed to process sensitive and special personal data?

In principle, yes	*Yes, but*	*No, unless*
	Sensitive personal data Yes, but be extra careful You are expected to take extra measures because of the greater risks.	Special personal data No, unless… The processing of these special categories of personal data is prohibited, unless a specific exception applies or the data subject has given explicit consent to the processing

Agenda

A5.34 – Legal obligation, Protection of PII and Privacy

GDPR – Personal data

GDPR – Processing activities

GDPR - Register of processing activities

GDPR - Controller VS. Processor and DPA

GDPR – DPO, privacy by design, requests, …

Conclusion

Processing requirements

Pursuant to the regulation, you may only process personal data for **well-defined, explicitly described and legitimate purposes**.

- You may therefore not process personal data without a purpose being determined. Collecting data because it '*may come handy in the future*' is therefore not allowed.

- You may not process the data for purposes other than those for which it was collected, unless:
  1. **The goals are compatible**.
  2. The data subject has **given permission** for further processing.
  3. **Legal necessity**, for example a request from the judiciary.

The further processing of personal data for scientific and historical research, for statistical purposes and for archiving purposes in the public interest is considered compatible in the regulation. These processing operations must be subject to appropriate technical and organizational safeguards.

When is processing justified?

Your processing is justified when you can base the purpose of the processing on one of the six legal bases:

Commonly used in business context are:

Common

1. the processing is necessary for the performance of a contract to which the data subject is a party, or in order to take steps at the request of the data subject prior to entering a contract; (‘**execution of an agreement with data subject**’)
2. the processing is necessary for compliance with a legal obligation to which the controller is subject; (‘**legal obligation**’)
3. the processing is necessary for the purposes of the legitimate interest pursued by the controller or by a third party, except where fundamental rights and freedoms of the data subject which require the protection of personal data outweigh those interests, in particular where the person concerned is a child. (‘**legitimate interest**’)

Uncommon

4. ‘**permission**’ (optional, non-essential tasks, e.g. research)
5. ‘**Vital interest**’ (provide medical care, prevent physical harm)
6. ‘**common interest**’ (for government agencies only)

Tip: use ‘permission’ last. It is better to use one of the other bases.

Appropriate bases

Before participating in a culinary event organized by your employer, you must provide information about food allergies. Which legal basises are appropriate for this, and which are not?

The options:

Permission
Execution of agreement
Legal obligation

Vital interests
General interest
Legitimate interest

Data is not required
Processing is not allowed

Agenda

A5.34 – Legal obligation, Protection of PII and Privacy

GDPR – Personal data

GDPR – Processing activities

Register of processing activities

GDPR - Controller VS. Processor and DPA

Privacy Statement

GDPR - Data Breaches

Register of processing activities

- For organizations with more than 250 employees, it is mandatory to keep a register of processing activities.

- Smaller organization? You must have a register when you process personal data:
  1. the processing which is not incidental. In practice, processing operations are rarely incidental. Consider, for example, the personal data of employees that you process. Or from your customers, clients or patients or residents, and/or;
  2. That pose a high risk to the rights and freedoms of the persons whose personal data you process and/or; (‘sensitive’)
  3. that fall under the category of special personal data. Such as data on religion, health and political preference or criminal data;

What should be included in a register of processing activities?

You must include the following items in the register:

Contact details:
- your name and contact details, or if applicable those of your representative;
- where applicable, the name and contact details of parties with whom you are joint data controllers;
- the contact details of your data protection officer if you have appointed one;

Processing;
- the processing purposes;
- a description of the categories of data subjects and of the categories of personal data;

Receivers:
- the categories of recipients to whom the personal data have been or will be disclosed, including recipients in third countries or international organizations;
- where applicable, transfers of personal data to a third country or an international organisation. You should also include the documents regarding the appropriate safeguards;

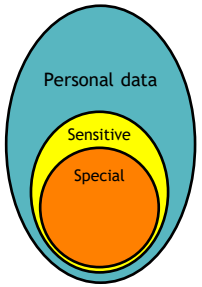
Terms and measures:
- if possible, the envisaged periods within which the different categories of data must be erased;
- if possible, a general description of the technical and organizational security measures.

5.34 Register of processing activities

- Most organizations are required to keep records of processing activities
- Record the type of personal data, with whom the data is shared and how information is secured

Template: Register of processing activities

ID	Purpose processing	Category of data subject	Category personal data	If possible, data retention term	Category of receivers	Shared outside EEA?	Technical/ organizational controls
1	Recruitment and personnel selection	Specific employees	BSN, cellphone number, name, address, city	2 weeks after job application	External HR-company	No	See InfoSec procedures



Template register of processing activities

Template for processing register:
https://ictinstitute.nl/gdpr-register-of-processing-actitvities-free-template/

All GDPR templates on GitHub:
https://github.com/swzaken/freetemplates

GDPR

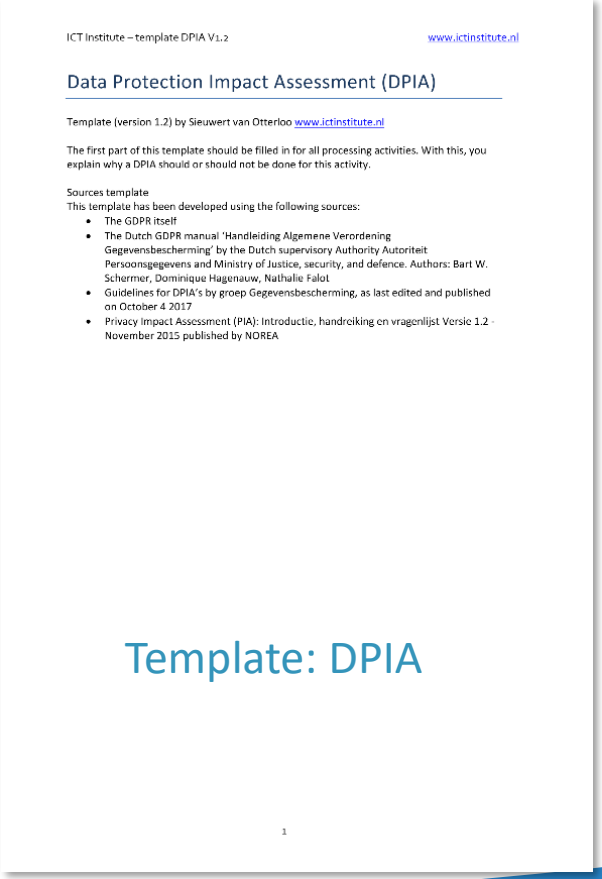
- GDPR-Data-Processing-Agreement.docx - A GDPR data processing agreement template that defines roles, responsibilities, and safeguards for processing personal data, including data subject rights, security measures, sub-processor conditions, international transfers, and audit rights.
- DPIA.docx - A Data Protection Impact Assessment template for identifying, assessing, and documenting privacy risks and mitigation measures.
- GDPR-Joint-Controllership-Agreement.docx - Template for a joint controllership agreement under GDPR, clarifying roles, responsibilities, and cooperation between joint controllers.
- Project plan.docx - A GDPR-focused project plan template for planning and managing GDPR implementation activities and milestones.
- Register of processing activities.xlsx - Template register for recording personal data processing activities in line with GDPR Article 30 requirements.

Data Protection Impact Assessment

If an intended processing of personal data is likely to pose a high risk to the rights and freedoms of natural persons, you must carry out a so-called data protection impact assessment prior to the processing.

A data protection impact assessment, also referred to in practice as a Privacy Impact Assessment (PIA) or **Data Protection Impact Assessment (DPIA)**, is an assessment of the effects of an intended processing activity on the protection of personal data and the rights and freedoms of data subjects.

In the DPIA, the effects for those involved are mapped out and assessed in a structured and standardized manner. Based on this, measures are taken to prevent or reduce these effects for those involved. You also demonstrate with a DPIA that you have met the requirements of the Regulation for that processing activity.



ICT Institute – template DPIA V1.2 www.ictinstitute.nl

Data Protection Impact Assessment (DPIA)

Template (version 1.2) by Sieuwert van Otterloo www.ictinstitute.nl

The first part of this template should be filled in for all processing activities. With this, you explain why a DPIA should or should not be done for this activity.

Sources template
This template has been developed using the following sources:

- The GDPR itself
- The Dutch GDPR manual 'Handleiding Algemene Verordening Gegevensbescherming' by the Dutch supervisory Authority Autoriteit Persoonsgegevens and Ministry of Justice, security, and defence. Authors: Bart W. Schermer, Dominique Hagenauw, Nathalie Falot
- Guidelines for DPIA's by groep Gegevensbescherming, as last edited and published on October 4 2017
- Privacy Impact Assessment (PIA): Introductie, handreiking en vragenlijst Versie 1.2 - November 2015 published by NOREA

1

Template: DPIA

List mandatory DPIA's

1. Covert surveillance
2. Blacklists
3. Fraud prevention
4. Credit scores
5. Financial situation
6. Genetic personal data
7. Health data
8. Partnerships
9. CCTV / camera surveillance
10. Flexible camera surveillance
11. Control employees
12. Location data
13. Communication data
14. internet of things
15. Profiling
16. Observation and influencing behavior
17. Biometric data

https://iapp.org/news/a/dutch-dpa-releases-final-dpia-list/
https://softwarezaken.nl/2019/12/autoriteit-persoonsgegevens-publiceert-dpia-lijst/

Question on DPIA

ACME has decided to join a 'customer view' initiative of the local business association to compile a list of 'internet scammers': people who often cancel orders, make unjustified complaints, request money back, etc.

ACME shares data (name, telephone, email) of ‘difficult customers’ with the business association and checks new customers against this register.

Does the customer view project include:

- ❑ evaluation of individuals or scoring;
- ❑ automated decision making with legal effect or similar material effect;
- ❑ systematic monitoring;
- ❑ sensitive data or data of a highly personal nature;
- ❑ data processed on a large scale;
- ❑ matching or merging of datasets;
- ❑ data related to vulnerable data subjects;
- ❑ innovative application of new technological or organizational solution;
- ❑ blocking a right, service or contract.

Agenda

A5.34 – Legal obligation, Protection of PII and Privacy

GDPR – Personal data

GDPR – Processing activities

GDPR - Register of processing activities

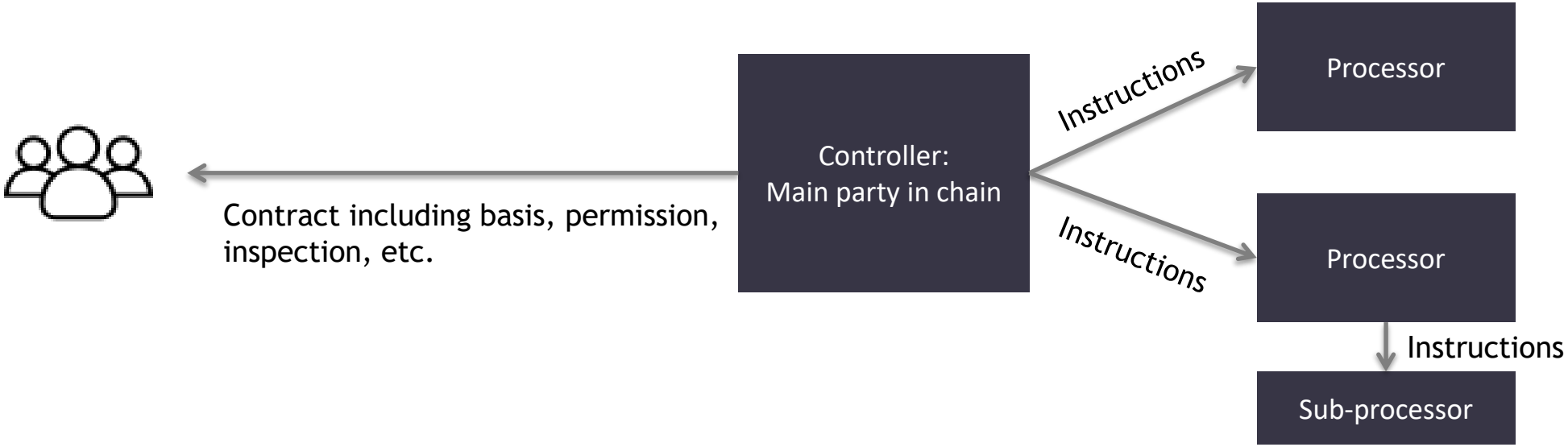
GDPR - Controller VS. Processor and DPA

GDPR – DPO, privacy by design, requests, …

Conclusion

Difference between controllers and processors

- There is always one **controller**. This is the party that makes decisions about how the process is set up and what data is collected. (goals and means)
- All parties that process **personal data** on behalf of the controller are **processors**.
- The GDPR mainly applies to the controller, and to a lesser extent to the processors.
- For example, the controller is legally responsible for reporting data breaches to the authority and handling data breaches (the processor is not).



Controller or processor?

Are the following parties controllers of processors?

1. Software supplier
2. Cloudplatform (Dropbox etc.)
3. Marketing agency that does a campaign on commission
4. Recruitment agency that has its own candidate file and devises campaigns itself.

Controller	Processor
Recruitment agency	Software supplier Cloudplatform (Dropbox etc.) Marketing agency

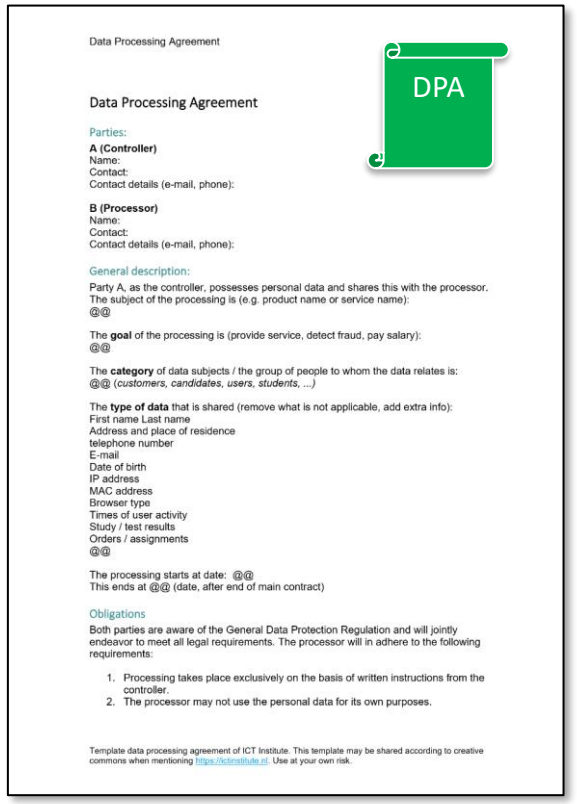
Data Processing Agreement (DPA) requirements

The following points **must** be stated in the agreement:

- The subject and the duration of the processing;
- The nature and purpose of the processing;
- The type of personal data and the categories of data subjects;

The agreement must state that the **processor**:

- Process the personal data only under the written instructions of the controller (even when transferring data to a third country);
- Ensures that access to that data is limited to authorized persons (bound by confidentiality agreement or legal obligation);
- applies at least the same level of personal data security as the controller;
- The controller provides support in fulfilling its obligations (responding to requests regarding the rights of data subjects);
- assists the controller in complying with its obligations of the security of personal data and the obligation to report data breaches;
- Erases or returns the personal data processed on behalf of the controller;
- The controller has all information available that is necessary to demonstrate compliance to the obligations of the regulation;
- Make agreements with regard to sub-processors to make sure they will also respect the terms of the data processing agreement



Data Processing Agreement

DPA

Data Processing Agreement

Parties:

A (Controller)
Name:
Contact:
Contact details (e-mail, phone):

B (Processor)
Name:
Contact:
Contact details (e-mail, phone):

General description:

Party A, as the controller, possesses personal data and shares this with the processor.
The subject of the processing is (e.g. product name or service name):
@@

The **goal** of the processing is (provide service, detect fraud, pay salary):
@@

The **category** of data subjects / the group of people to whom the data relates is:
@@ (*customers, candidates, users, students, ...*)

The **type of data** that is shared (remove what is not applicable, add extra info):
First name Last name
Address and place of residence
telephone number
E-mail
Date of birth
IP address
MAC address
Browser type
Times of user activity
Study / test results
Orders / assignments
@@

The processing starts at date: @@
This ends at @@ (date, after end of main contract)

Obligations

Both parties are aware of the General Data Protection Regulation and will jointly endeavor to meet all legal requirements. The processor will in adhere to the following requirements:

1. Processing takes place exclusively on the basis of written instructions from the controller.
2. The processor may not use the personal data for its own purposes.

Template data processing agreement of ICT Institute. This template may be shared according to creative commons when mentioning https://ictinstitute.nl. Use at your own risk.

Template: DPA

Standard agreements – reverse DPA's

Many standard service providers only offer a standard data processing agreement. You can often download this from the website. It is not possible to agree on additional security measures.

Atlassian Data Processing Addendum
Last updated: September 19, 2022

We make it easy for Atlassian customers to sign and submit our Data Processing Addendum (DPA). The DPA helps meet onward transfer requirements under the GDPR. The DPA is pre-signed by Atlassian and can be found below. Once you've signed the DPA, email a signed copy to dpasubmission@atlassian.com.

Atlassian: https://www.atlassian.com/legal/data-processing-addendum
Microsoft: https://www.microsoft.com/licensing/docs/view/Microsoft-Products-and-Services-Data-Protection-Addendum-DPA
Outsystems: https://www.outsystems.com/legal/master-subscription-agreement/data-processing-agreement/

Transferring data abroad

Within the EU/Economic European Area (EEA) no problem,

beyond that, an export mechanism is required (Chapter V GDPR):

- Adequacy decision (for countries selected by the European Commission)
- EU Standard Contracts (Standard Contractual Clauses)
- Binding Corporate Rules (BCR)
- Approved certification mechanism

Exceptions specific situations, e.g.:

- Explicit consent of the person concerned
- Necessary for the execution of the agreement
- Necessary for legal action

Link adequacy decisions (including Canada, Japan, UK, New Zealand)
https://ec.europa.eu/info/law/law-topic/data-protection/international-dimension-data-protection/adequacy-decisions_en

Agenda

A5.34 – Legal obligation, Protection of PII and Privacy

GDPR – Personal data

GDPR – Processing activities

GDPR - Register of processing activities

GDPR - Controller VS. Processor and DPA

GDPR – DPO, privacy by design, requests, …

Conclusion

5.34 Privacy statement

People can find a privacy statement on the public website. It states:

- Personal data processed by the company
- With what purpose
- On what basis
- Data retention period
- Sharing data with third parties
- View personal data
- How company protects personal data

Note: You also need a privacy statement or similar document for your own employees.

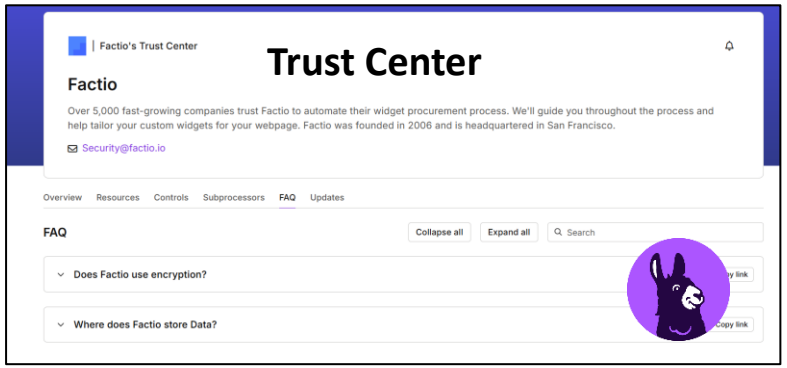
Privacy statement

Privacystatement SoftwareZaken/ ICT Institute

Dit is het privacystatement van SoftwareZaken (handelsnaam van Otterloo Ventures BV) en ICT Institute (handelsnaam van ICTI BV), hierna genoemd SoftwareZaken/ ICT Institute. SoftwareZaken/ ICT Institute neemt privacy zeer serieus en de mensen van SoftwareZaken/ ICT Institute doen hun best ieders privacy te respecteren, zo min mogelijk persoonsgegevens te verwerken en alle persoonsgegevens zo goed mogelijk te beschermen.

Privacy op de softwarezaken.nl website

Op softwarezaken.nl wordt zo min mogelijk gebruik gemaakt van cookies, trackers en andere volgtechnologie. SoftwareZaken/ ICT Institute houdt geen bezoekers-statistieken bij. Dit is gecontroleerd en kunt u zelf controleren met privacybadger.



https://ictinstitute.nl/ict-institute-information-security-and-privacy/

5.34 Privacy by Design principles

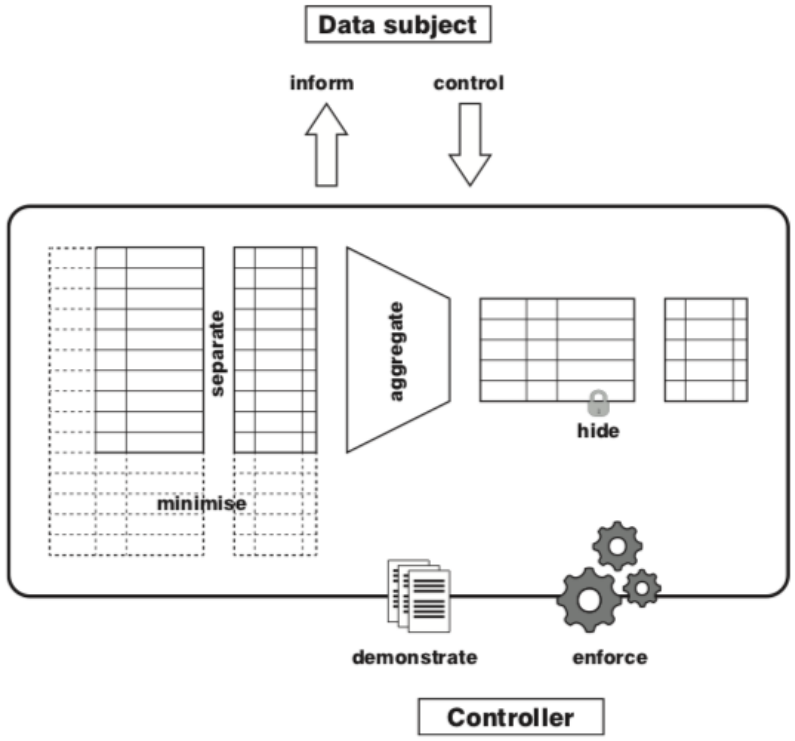


Fig. 1. The database metaphor of the eight privacy design strategies.

Possible practical implementation:

- Don't ask for a user photo or date of birth
- Allow users to manage their data themselves
- Ensure that customer data or user data are deleted
- Make reporting in such a way that you cannot see individual orders.
- Separate customer names and product names into separate tables
- Good logging and logging reporting

https://www.cs.ru.nl/~jhh/publications/pds-booklet.pdf

Which design is better?

Q1: survey design

What is your age? _____

What is your age?
a) 20 or younger
b) 21-40
c) 41-60
d) 61 and older

Q2: candidate overview display screen

Candidate A

Click here for contact details

Candidate B

Name: Ahmed Mostafa
Address: Biltstraat 1, 3500 AA Utrecht
Phone nr: 06 - 1234 5678

5.34 Data Protection Officer (DPO)

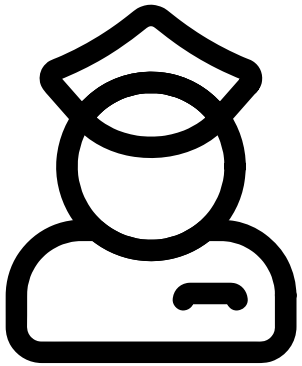
A DPO is a formal role defined in the GDPR. It is not required to have one!

Necessary if:

- Company primarily processes sensitive data on a regular basis/large scale
- Company extensively processes special categories of personal data / personal data related to criminal convictions and offenses
- e.g. political affiliations, religious beliefs, biometric data, etc.
- Company is a public authority or agency

DPO:

- Maintains contact with the Supervisory Authority
- Advises the organization on correct and careful handling of personal data, including obligations from the GDPR
- Creates activity report, reports to CEO
- May not have conflicting roles, i.e. not CEO, CISO, SO, CFO, etc.



https://softwarezaken.nl/2018/04/het-aanstellen-van-een-functionaris-voor-gegevensbescherming/ (NL)

The rights of data subjects

The data subject has:

- the right to information about the processing;
- the right to access to their data;
- the right to have the data corrected if it is incorrect;
- The right to have data deleted and ‘the right to be forgotten’;
- The right to restriction of data processing;
- The right to object to data processing;
- The right to transfer their data (data portability);
- The right to not be subject to automated decision-making.

As long as a request is not excessive, does not involve a disproportionate amount of effort, does not infringe on someone else’s privacy, and the person concerned can be identified, every request must be granted!

Examples deletion requests

[redacted]

To Whom It May Concern,

I am hereby requesting immediate erasure of personal data concerning me according to Article 17 GDPR.

Please erase all personal data concerning me as defined by Article 4(1) GDPR.

Best Regards,

[redacted]

In practice, we most often encounter the right to be forgotten.

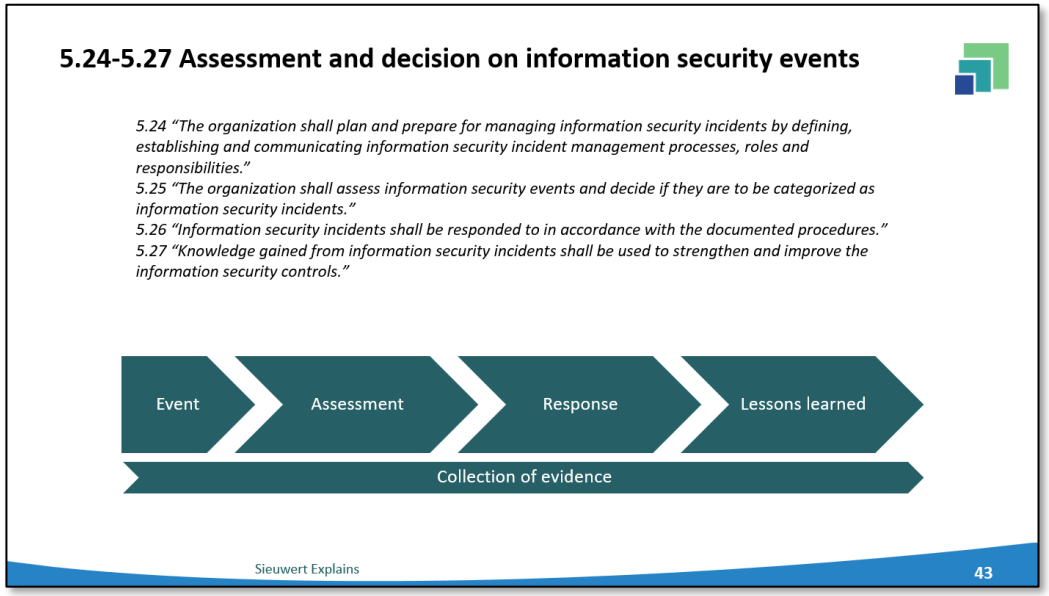
The form of the request does not matter. If a person makes it clear that the processing of his/her data is no longer necessary, the data must be deleted.

However, the right to delete is not an absolute right! Sometimes you as an organization are obliged to keep certain data. For example, financial administration, for about 7 years.

Recall: security incidents (A 5.24-5.27)

Security incidents are events that affect the confidentiality, integrity and/or availability of information. For example:

- Mail sent incorrectly, opened return
- To, CC, BCC error sending mail
- Data deleted, Backup restore necessary
- Ransomware, Malware, Viruses, Hack Attack
- Burglary in office
- Theft, lose computer, mobile, tablet
- Staff out of service with access and password
- Incorrect access structure in program



When is an incident a data breach?

A data breach is a breach of security that leads to the destruction, loss, alteration, unauthorized disclosure or unauthorized access to personal data transmitted, stored or otherwise processed.

Indicate whether or not it is a data breach in the following situations:

- To, CC, BCC error sending mail — Data breach
- PEN testers find leaks in an application with personal data
- Annual report with price-sensitive information is accidentally published too early

NL#TIMES TOP STORIES HEALTH CRIME POLITICS BUSINESS TECH

Odido's headquarters building in The Hague. Undated - Credit: Odido / Supplied - License: All Rights Reserved

CRIME ODIDO CYBER ATTACK HACK DATA BREACH DATA LEAK » MORE TAGS

SHARE THIS ARTICLE:

THURSDAY, 12 FEBRUARY 2026 - 13:26

Odido cyber attack: Hackers gained access to 6.2 million people's data

Hackers have managed to break into Odido's systems and gained access to a file containing customer data for potentially 6.2 million people, a spokesperson for the telecom provider confirmed to NOS.

The accessed data includes full names, addresses, phone numbers, customer numbers, email addresses, account numbers, date of birth, and passport and driver's license information, the spokesperson said. "No passwords, call logs, or billing information were involved."

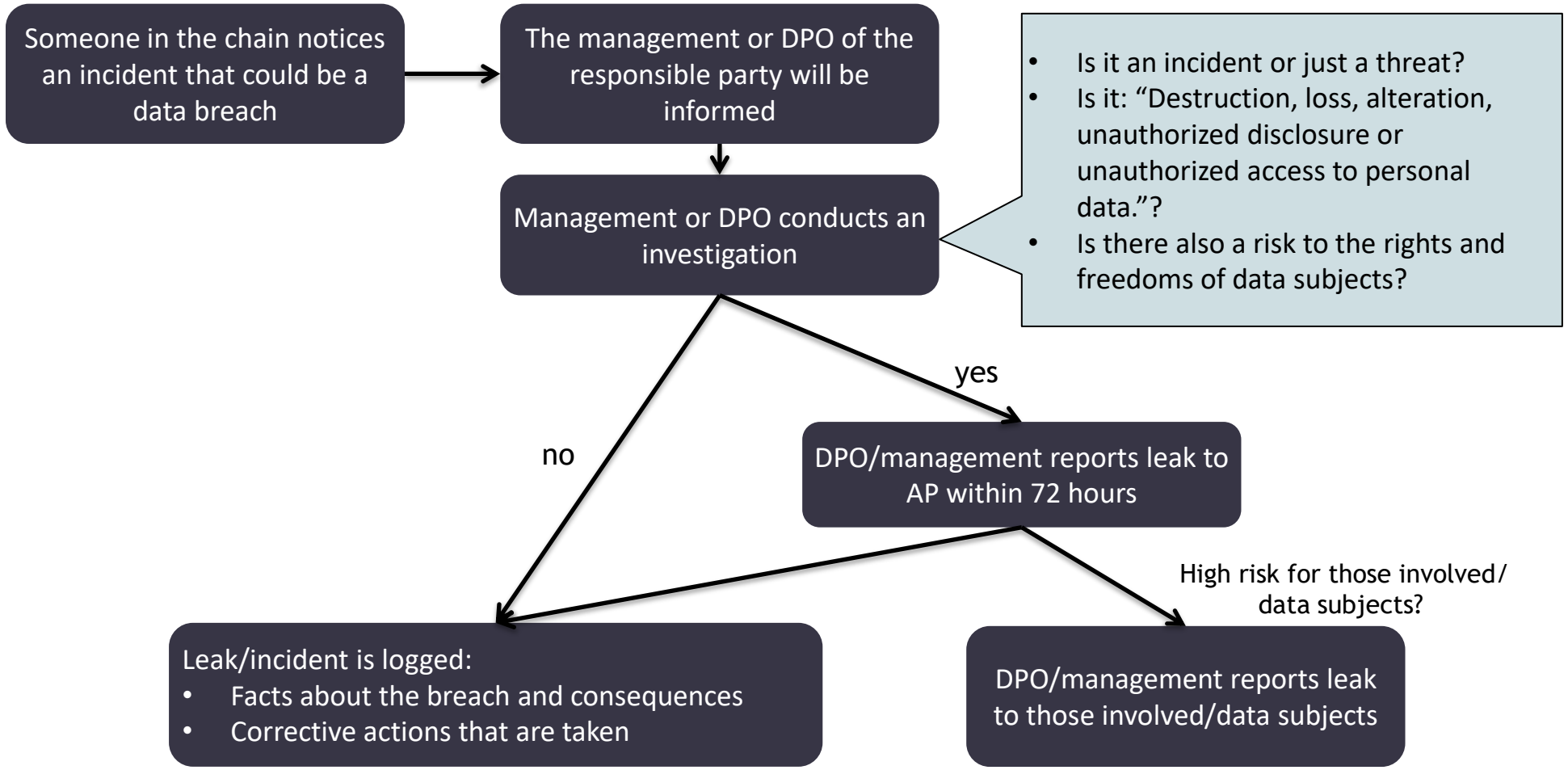
"Based on an investigation, the incident involves personal data from a customer contact system used by Odido.

The hack did not affect Odido's services. Customers can continue to make calls, use the internet, and watch television as usual.

Odido has reported the breach to the Dutch Data Protection Authority (AP). The company will email all affected customers as soon as possible.

https://nltimes.nl/2026/02/12/odido-cyber-attack-hackers-gained-access-62-million-peoples-data

Data breach notification obligation



Sample notification to data subjects

Dear colleague,

In response to a report about a possible data breach, RRR reported a data breach to the Dutch Data Protection authority on …

The old Sharepoint environment of the BTO contained a file containing the names of external employees of the …, including their rates. Your details were also listed. The file was accessible to Sharepoint users. It is unclear whether any employees actually gained access to the document. Immediately after establishing the data leak, access to the file via Sharepoint was made impossible.

We regret that this could have happened. As a result of the report, the old environment was phased out more quickly. … An investigation is also currently underway into improving the logging so that it can be determined in the future whether there has been unauthorized access.

We hope to have informed you sufficiently with this. If you have any questions, please contact the acting data protection officer …

Yours sincerely,

Manager Legal & Compliance

Agenda

A5.34 – Legal obligation, Protection of PII and Privacy

GDPR – Personal data

GDPR – Processing activities

GDPR - Register of processing activities

GDPR - Controller VS. Processor and DPA

GDPR – DPO, privacy by design, requests, …

Conclusion

Conclusion

GDPR compliance is very important if you are in the EU or serve EU customers

You must make your company GDPR compliant:

- if you want to become ISO 27001 certified
- If you deal with consumers and their data, since they can make requests or complaints
- If you plan to raise capital

Any audit on ISO 27001 should contain GDPR compliance checks, including:

- Privacy statement
- Register of processing activities
- Data breach reporting
- Data processing agreements

Overview of actions for management of an average company

To be demonstrably compliant, you must take the following measures:

Register

- keep a record of your processing activities
- when you use the basis of consent, recording how you request consent and documenting evidence that this consent has actually been given;
- documenting the appropriate safeguards used when transferring data outside the European Union (see Chapter);

Design processes

- documenting your DPIAs;
- Update processes and training to implement data protection by design and by default.
- provide information to the data subjects in writing (for example in the form of a privacy statement);

Contracting

- draw up processing agreements in accordance with the requirements of the Regulation for every use of processors;

Procedures

- documenting your processes and procedures to ensure the rights of the data subjects;
- document your procedures for dealing with data breaches;
- if proportionate to the processing activities, the writing of an appropriate data protection policy;
- keep a record of data breaches that have occured in your organization

Free templates and articles

Overview:
- https://ictinstitute.nl/free-templates/
- https://github.com/swzaken/freetemplates

Documents:
- https://ictinstitute.nl/gdpr-register-of-processing-actitvities-free-template/
- https://ictinstitute.nl/gdpr-template-data-processing-agreement
- https://ictinstitute.nl/gdpr-dpia-free-template/

Information:
- https://ictinstitute.nl/gdpr-privacy-practical-guide/
- https://ictinstitute.nl/iso-27001-requirements-summary/
- https://ictinstitute.nl/information-security-interest-group/

creative commons

At ICT Institute we believe in open standards and sharing knowledge. That is why we make a lot of information available for free. We do this under Creative Commons. We hope many people use it.

Thanks for watching *SieuwertExplains*

Subscribe at youtube.com/@sieuwertexplains

SieuwertExplains is a free learning resource, where you can learn about information security, privacy and standards such as ISO 27001. The channel is created by ICT Institute, an IT advisory firm. Call us for audits, compliance support or IT reviews!
https://ictinstitute.nl/sieuwertexplains/